

AI Governance Readiness — Summary Report

Arenal Play (fictional online casino operator) · generated 2026-09-29

- AI ESTATE
- RISK + OWNERSHIP
- 90–180 DAY ROADMAP

Run mode	Demo
Evidence	9 available of 9, plus customer pre-work
Decision supported	Approve the minimum governance model and immediate control priorities



DELIVERABLE 01

SYNTHETIC DEMO DATA

Executive Governance Readiness View

What leadership needs to decide, based on the evidence in scope.

AI assets

13

ownership gaps

9

external-data concerns

7

unknown tools

4

EXECUTIVE INTERPRETATION

AI use is active across 6 teams, but the estate is not yet represented by one accountable inventory. 9 of 13 AI assets lack a confirmed owner, and 8 were found in evidence but not declared in pre-work. The highest-value first action is to establish ownership and a sanctioned developer-AI control model before expanding technical discovery.
Declared in pre-work: 5 · found in evidence: 13 · not declared: 8

PROPOSED DECISION · IMPLEMENT WITH CONDITIONS

Proceed with the governance foundations while the roadmap closes 7 critical or high conditions, with 1 paused until its condition is met.

- Approve immediate conditions: rotate the committed key and pause agent access to production data until a permission boundary exists.
- Mandate a federated AI register with a named business and technical owner for every AI asset.
- Adopt a sanctioned developer-AI standard with enterprise accounts, and use targeted discovery only where UNKNOWNs change the control design.

Decision support only; the executive sponsor makes the final call.

DELIVERABLE 02

SYNTHETIC DEMO DATA

AI Estate & Ownership Register

Authoritative owner, lifecycle and evidence status for each AI initiative and tool.

AI / use case	Business owner	Technical owner	Pattern	Data	Stage	Tier	Governance status	Pre-work
Customer Support Assistant	Customer Operations	UNKNOWN	GenAI/RAG on OpenAI API	Restricted	Pilot	High	Owner named · technical owner missing	Declared
Fraud Investigation Assistant	Risk Operations	Fraud analytics team (assumed)	OpenAI API	Restricted	PoC	High	Data path UNKNOWN	Declared
Marketing Content Generator	Marketing	UNKNOWN	ChatGPT	Internal	Production	Low	Account model UNKNOWN	Declared
Developer Coding Assistant	Engineering	Engineering Enablement	GitHub Copilot, 42 developers	Confidential	Production	Medium	Approved tool · policy incomplete	Declared
ChatGPT Enterprise	IT	IT Workplace	OpenAI, 18 users	Confidential	Production	Medium	Sanctioned · usage rules unpublished	Declared
Microsoft 365 Copilot	IT	IT Workplace	Microsoft, 20 users	Confidential	Pilot	Medium	Pilot · not in pre-work	New
KYC document assist	Compliance	IT Applications	KYC-Scan Pro (vendor)	Restricted	Production	High	Vendor AI terms missing	New
Responsible-gambling early warning	UNKNOWN	UNKNOWN	Notebook, runtime unknown	Unknown	Unconfirmed	High	Existence UNKNOWN	New
Personal ChatGPT	UNKNOWN	UNKNOWN	OpenAI consumer, 11 users	Unknown	Unsanctioned	High	Unmanaged	New
Claude / Claude Code	UNKNOWN	UNKNOWN	Anthropic, 7 users	Unknown	Unsanctioned	High	Account ownership UNKNOWN	New
Community Postgres MCP server	UNKNOWN	dev-tools committer (assumed)	Open-source MCP server	Restricted	Unsanctioned	High	Unapproved agent connection	New
Sandbox AI workloads	UNKNOWN	UNKNOWN	Amazon Bedrock, SageMaker	Unknown	Unknown	Medium	No owner tag	New
Agentic IDE tools	UNKNOWN	UNKNOWN	Cursor, Cline	Confidential	Unsanctioned	High	Unmanaged installs	New

DELIVERABLE 03

SYNTHETIC DEMO DATA

Developer AI / Shadow AI View

Sanctioned enterprise tools separated from unknown or unmanaged usage.

GitHub Copilot

42 developers · Sanctioned · Data: Source code · Risk: **MODERATE**

Personal ChatGPT

11 users · Unknown · Data: UNKNOWN · Risk: **HIGH**

Cursor

5 users · Unknown · Data: Source code · Risk: **ELEVATED**

Community Postgres MCP server

dev-tools repo · Unsanctioned · Data: Production replica · Risk: **HIGH**

ChatGPT Enterprise

18 users · Sanctioned · Data: Business data · Risk: **MODERATE**

Claude / Claude Code

7 users · Unknown · Data: Source code possible · Risk: **ELEVATED**

Cline agent extension

3 laptops · Unmanaged · Data: Source code, terminal · Risk: **HIGH**

OPTIONAL DISCOVERY · AUTHORIZED IAM / CASB / PROXY / GIT / CLOUD EVIDENCE CAN CONFIRM OR REFUTE UNKNOWN USAGE

DELIVERABLE 04

SYNTHETIC DEMO DATA

Priority Risks & Conditions

Each condition names the risk owner and what must be true before the next gate.

R1 · CRITICAL · VP Engineering API key committed to the promo-engine repository Condition: Key revoked and rotated, with secret scanning in CI, before the next release. Evidence: E3 Code Remediate · Next gate G3 Security / eval	R2 · CRITICAL · VP Engineering AI tooling wired to the production database replica through MCP Condition: Human approval, kill switch and tool permission boundary before any agent touches production data. Evidence: E3 Code Block / pause · Next gate G3 Security / eval	R3 · HIGH · Customer Operations + Engineering Customer Support Assistant handles player data with no technical owner Condition: Named technical owner and documented data path before production. Evidence: E3 Code Remediate · Next gate G2 Design / data
R4 · HIGH · CISO / Engineering Personal or unmanaged GenAI use cannot be ruled out for source code Condition: Sanctioned-tool standard plus targeted discovery evidence. Evidence: E2 People, E4 Network, E5 SaaS Remediate · Next gate G0 Intake	R5 · HIGH · Executive sponsor Responsible-gambling model with no owner or known data Condition: Confirm existence, name an owner and complete an impact review before any player-facing use. Evidence: E2 People Assure · Next gate G1 Risk tier	R6 · HIGH · Procurement + Compliance KYC vendor processes ID documents without AI data-use terms Condition: AI data-use clause and DPA review before renewal or enabling new AI features. Evidence: E8 Contracts Remediate · Next gate G2 Design / data
R7 · HIGH · Endpoint Engineering + DevSecOps Unmanaged coding agents can run commands on developer laptops Condition: Allow-listed agent tools with approved permission boundaries. Evidence: E7 Endpoint Remediate · Next gate G3 Security / eval	R8 · HIGH · CIO / CTO Several AI initiatives lack an accountable owner or approval gate Condition: Federated AI register plus owner attestation and a tiered intake gate. Evidence: E9 Governance Remediate · Next gate G0 Intake	R9 · HIGH · Risk Operations Fraud Investigation Assistant sends analyst notes to an external API Condition: Accountable human decision and a documented evidence path before production. Evidence: E3 Code Assure · Next gate G2 Design / data

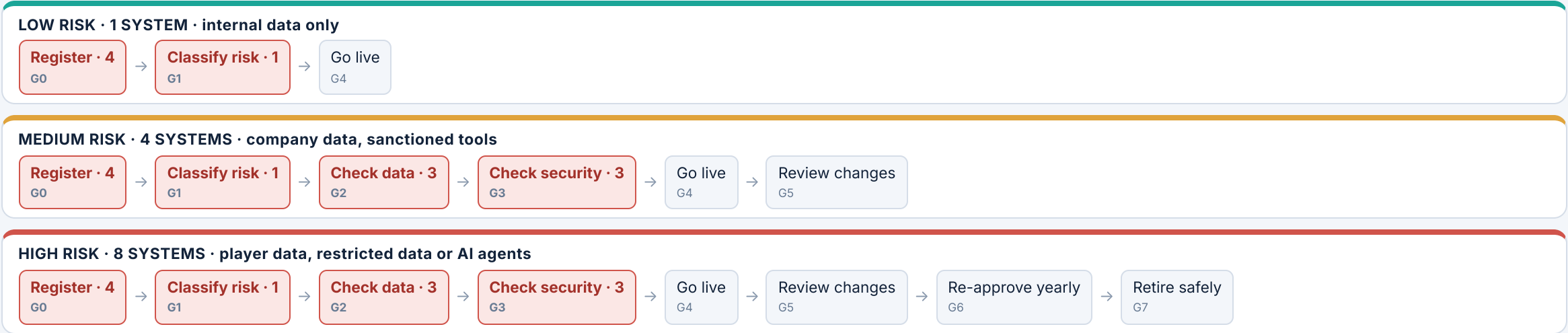
Medium: R10 AI workloads running in an untagged sandbox account · R11 Traffic to an unrecognized AI endpoint

DELIVERABLE 05

SYNTHETIC DEMO DATA

Target AI Governance Operating Model

Every AI system follows a path. The riskier it is, the more checks it passes.



Red steps are blocked today by open conditions (number = how many). Step codes G0–G7 shown under each step.

✓ WHAT HAS TO CHANGE

Control	Today (pre-work)	Target
AI intake and registration	No enterprise register	Federated register with owner attestation
Named business and technical ownership	Varies by team	Both owners named for every entry
Risk and impact classification	No common AI-specific method	Three-tier method at the Classify risk step
Security and privacy review	Reused inconsistently	AI-specific checks at the data and security steps
Vendor and model review	Tool-by-tool, AI terms not explicit	AI data-use clause required
Production approval and change	Project-specific	Go live and Review changes steps

Governance Readiness Scorecard

Average 1.4 of 4 across domains with evidence. A high score is not “ISO certified”; it means evidenced and repeatable.

0 · Absent	1 · Emerging	2 · Defined	3 · Managed	4 · Assured
No practice or evidence	Ad hoc; depends on individuals	Documented, not applied consistently	Applied consistently, with owners and evidence	Measured, tested and independently verified
AI inventory and ownership No enterprise register; ownership varies by team				1 · Emerging Full
Developer AI and acceptable use Copilot and ChatGPT Enterprise sanctioned through SSO; usage rules unpublished				2 · Defined Full
Risk and impact No AI-specific tiering or impact method				0 · Absent Full
Data and privacy Classification standard and DPAs exist, but predate GenAI				2 · Defined Full
Security Identity, endpoint and network monitoring are managed and surfaced these findings; AI-specific controls lag				3 · Managed Full
Third-party AI Vendor review is tool-by-tool; AI data-use clauses missing				1 · Emerging Full
Lifecycle and assurance A change process exists, but has no AI-specific gates				1 · Emerging Full

30/60/90/180-Day Implementation Roadmap

Sequencing that turns assessment findings into accountable implementation.

0–30 DAYS

- Revoke and rotate the committed key; turn on secret scanning **R1**
- Remove the production MCP config; freeze new MCP servers **R2**
- Block unmanaged agent tools through endpoint policy **R7**
- Publish an interim sanctioned developer-tool list **R4**
- Stand up the AI register and collect owner attestations **R8**
- Pause until met: Human approval, kill switch and tool permission boundary before any agent touches production data **R2**

31–60 DAYS

- Name a technical owner and map the support assistant data path **R3**
- Developer AI standard and enterprise accounts through SSO **R4**
- Risk tiering method and approval workflow **R8**
- Third-party AI rules and KYC vendor AI clause **R6**
- Identify and block or sanction the unrecognized endpoint **R11**

61–90 DAYS

- Lifecycle gates G2–G5 live for high-tier AI **R8**
- Security and data standard for AI, including MCP catalog **R2**
- Document the fraud decision and evidence path **R9**
- Enforce owner tags on AI cloud services **R10**
- Assurance review: Confirm existence, name an owner and complete an impact review before any player-facing use **R5**
- Assurance review: Accountable human decision and a documented evidence path before production **R9**

91–180 DAYS

- Impact review for the responsible-gambling model **R5**
- Discovery automation and evidence dashboard
- Reassessment and recertification cadence (G6)

EXECUTIVE RECOMMENDATION · IMPLEMENT WITH CONDITIONS (PROPOSED)

Implement governance foundations now; use technical Shadow AI discovery only where the remaining UNKNOWNs materially change risk or control design.

APPENDIX A

SYNTHETIC DEMO DATA

Critical UNKNOWNs and Evidence Owners

UNKNOWN is a valid answer when it has an owner and a date.

What is unknown	Evidence that resolves it	Owner	Due
Whether the key is active and what it was used for	Provider key usage logs and a git history scan	VP Engineering	Within 7 days
Which developers and agents used it, and what they queried	MCP server and replica access logs	VP Engineering	Within 7 days
Retention and data-use terms on the API account	API account settings and a data-flow diagram	Customer Operations + Engineering	Before day 30
What the uploaded content contained and which accounts were personal	CASB content classes and IAM personal-account signals	CISO / Engineering	Before day 30
Whether it exists and whether it influences how players are treated	Owner attestation and the notebook location	Executive sponsor	Before day 30
Whether either vendor retains or trains on submitted data	Vendor contracts and DPAs	Procurement + Compliance	Before day 30
Which models these agents send code to	Endpoint management policy report	Endpoint Engineering + DevSecOps	Before day 30
Whether informal approvals happened	Change records and architecture intake forms	CIO / CTO	Before day 30
Which fields leave, and who makes the final fraud decision	Notebook review and the fraud decision procedure	Risk Operations	Before day 30
What data these workloads use	Cloud tagging report and workload owners	Cloud Platform	Before day 60
Service identity and data sent	Host investigation and proxy payload metadata	Security Operations	Before day 60

APPENDIX B

SYNTHETIC DEMO DATA

Review Record and Evidence Coverage

Human decisions on the agents’ proposals, and the evidence each conclusion rests on.

ID	Rating decision	Disposition	Proposed
R1	Rating accepted	Remediate	Remediate
R2	Rating accepted	Block / pause	Block / pause
R3	Rating accepted	Remediate	Remediate
R4	Rating accepted	Remediate	Remediate
R5	Rating accepted	Assure	Assure
R6	Rating accepted	Remediate	Remediate
R7	Rating accepted	Remediate	Remediate
R8	Rating accepted	Remediate	Remediate
R9	Rating accepted	Assure	Assure

ID	Evidence source	Availability	Owner
PW	Customer pre-work workbook	Available	Executive sponsor
E1	Identity provider export	Available	Identity team
E2	Developer AI survey	Available	Engineering managers
E3	Repository scan	Available	Developer Platform
E4	Proxy and DNS log sample	Available	Security Operations
E5	SaaS discovery (CASB) report	Available	Security Operations
E6	Cloud billing and expenses	Available	Cloud Platform
E7	IDE extension inventory	Available	Endpoint Engineering
E8	Vendor and contract register	Available	Procurement
E9	Policies and approval records	Available	PMO / Governance

Generated by the AI Governance Readiness demo (Governance Analyzer). Synthetic data for illustration; scores and figures are not findings about any real organization.